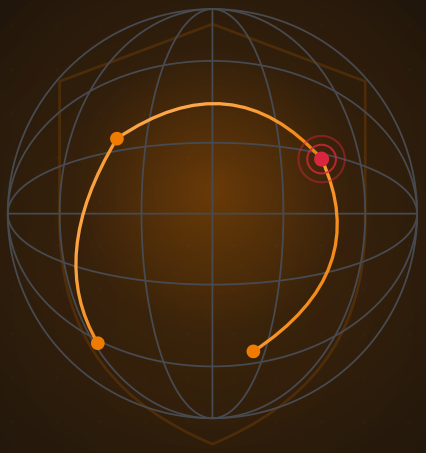


THREAT PULSE

ÉDITION MAROC

WEEKLY CYBER THREAT BRIEFING · MOROCCO

SEMAINE DU 19 AU 25 OCTOBRE 2026 · WEEK IN REVIEW

Au sommaire : l'alerte **« critique »** de la DGSSI sur les failles **PHP2Shell**, la même alerte côté **Tunisie**, et le détournement d'un accès de **sauvegarde Microsoft 365**.
*Inside: the DGSSI **"critical"** alert on the **PHP2Shell** flaws, the same alert in **Tunisia**, and a hijacked **Microsoft 365 backup** access.*

Bienvenue dans **Threat Pulse — Édition Maroc**, votre point hebdomadaire, en langage clair, sur les cybermenaces qui concernent les entreprises marocaines. Cette semaine, la **DGSSI** a classé « critique » une alerte sur deux failles **PHP** qui touchent une grande partie des sites web du pays. Côté mondial, un accès de **sauvegarde Microsoft 365** détourné a ouvert des dizaines d'organisations. *Welcome to Threat Pulse — Morocco Edition, your plain-language weekly on the cyber threats that matter to Moroccan businesses. This week the DGSSI rated "critical" an alert on two PHP flaws that affect a large share of the country's websites. Globally, a hijacked Microsoft 365 backup access opened dozens of organisations.*

EN UN COUP D'ŒIL · CETTE SEMAINE / AT A GLANCE

9,2/10
Gravité de chacune des deux failles PHP « PHP2Shell » (échelle CVSS v4)
Severity of each of the two "PHP2Shell" PHP flaws (CVSS v4)
PHP · DGSSI · 21 OCT. 2026

75 %
des sites .ma identifiables fonctionnent sous PHP (75,4 %, contre 69,3 % dans le monde)
of identifiable .ma sites run on PHP (75.4% vs 69.3% worldwide)
W3TECHS VIA MÉDIAS24 · 21 OCT. 2026

4
versions de PHP corrigées : 8.2.35, 8.3.36, 8.4.27 et 8.5.12
PHP versions fixed: 8.2.35, 8.3.36, 8.4.27 and 8.5.12
PHP · 21 OCT. 2026

LA MENACE PHARE DE LA SEMAINE / THIS WEEK'S HEADLINE THREAT

DGSSI · BULLETIN D'ALERTE « CRITIQUE » · 21 OCTOBRE 2026

Failles PHP « PHP2Shell » : la DGSSI donne l'alerte maximale

"PHP2Shell" PHP flaws: the DGSSI raises its top alert

NIVEAU · LEVEL
CRITIQUE · CRITICAL

9,2/10 · code de démonstration public · exploitation massive non confirmée / *public proof-of-concept · mass exploitation not confirmed*

Que se passe-t-il ? / What's happening

Le 21 octobre, l'équipe PHP a publié des correctifs pour **deux failles critiques** (**CVE-2026-109618** et **CVE-2026-109619**) qui permettent à un attaquant d'**exécuter du code à distance, sans identifiant**, sur certains serveurs — surtout ceux en **mod_php**. La **DGSSI** a publié le jour même un bulletin classé **« critique »** ; la NSA américaine appelle aussi à patcher d'urgence. Un code de démonstration est **déjà public** ; aucune exploitation massive n'est confirmée, mais des sites publics ont été mis hors ligne par précaution en Europe.

On 21 October the PHP team released fixes for two critical flaws that let an attacker run code remotely, with no login, on some servers — mainly those using mod_php. The DGSSI issued a "critical" bulletin the same day; the US NSA also urges urgent patching. Proof-of-concept code is already public; no mass exploitation is confirmed, but public sites in Europe were taken offline as a precaution.

Qui est concerné ? / Who's affected

Tout site ou application sous PHP — dont **WordPress, Drupal et Joomla** — chez vous ou chez votre hébergeur. Les versions **PHP 8.1 et antérieures** ne reçoivent plus de mises à jour régulières. Le chiffre de 75,4 % mesure l'**usage** de PHP, pas le nombre de sites réellement vulnérables.

Any site or application running PHP — including WordPress, Drupal and Joomla — at your premises or at your host. PHP 8.1 and earlier no longer receive regular updates. The 75.4% figure measures PHP use, not how many sites are actually vulnerable.

Pourquoi c'est important / Why it matters

Il faut corriger **PHP sur le serveur** : mettre à jour WordPress ou ses extensions ne suffit pas. Des mesures provisoires (désactiver **session.upload_progress.enabled**, limiter la taille des requêtes) réduisent le risque sans l'éliminer. Une troisième faille (**CVE-2026-115560**, certaines configurations de session) sera corrigée à la prochaine version.

PHP must be fixed on the server itself: updating WordPress or its plugins is not enough. Temporary measures (disable session.upload_progress.enabled, limit request sizes) reduce the risk without removing it. A third flaw (CVE-2026-115560, certain session setups) will be fixed in the next release.

À faire cette semaine / What to do

- [ ] Demandez à votre équipe web ou hébergeur la **version de PHP** utilisée et passez à **8.2.35, 8.3.36, 8.4.27 ou 8.5.12** ; si c'est PHP 8.1 ou plus ancien, planifiez la migration.
  Ask your web team or host which PHP version is in use and move to 8.2.35, 8.3.36, 8.4.27 or 8.5.12; if it is PHP 8.1 or older, plan the migration.
- [ ] Si la mise à jour est impossible aujourd'hui : appliquez les **mesures provisoires**, mettez hors ligne les sites non essentiels et surveillez les journaux.
  If you cannot update today: apply the temporary measures, take non-essential sites offline and watch the logs.

AUTRES MENACES À CONNAÎTRE / OTHER THREATS WORTH KNOWING

MOYEN MEDIUM

Maroc : pas d'autre incident — mais PHP est partout sur les sites .ma

Morocco: no other incident — but PHP is everywhere on .ma sites

Aucun autre incident marocain majeur n'a été trouvé cette semaine. Le chiffre à retenir : **75,4 %** des sites .ma dont le langage est identifiable utilisent PHP, contre **69,3 %** dans le monde (W3Techs, 21 octobre) — l'exposition marocaine à cette alerte est donc plus large que la moyenne.

No other major Moroccan incident was found this week. The figure to remember: 75.4% of identifiable .ma sites use PHP, versus 69.3% worldwide (W3Techs, 21 October) — Morocco's exposure to this alert is wider than average.

À retenir : listez tous vos sites, y compris les anciens sites d'événement ou de campagne — ce qui n'est pas listé n'est pas corrigé.

Takeaway: list all your sites, including old event or campaign sites — what is not listed is not patched.

MOYEN MEDIUM

Tunisie : la même alerte, en parallèle

Tunisia: the same alert, in parallel

Le 21 octobre, la **Tunisie** (agence ANCS, bulletin tunCERT/Vuln.2026-657) a publié la même alerte. Le **CERT-FR** (mise à jour du 22 octobre) confirme des codes de démonstration pour les deux failles, sans exploitation active confirmée. Le nombre de sites vulnérables en Afrique est inconnu.

On 21 October, Tunisia (ANCS agency, bulletin tunCERT/Vuln.2026-657) issued the same alert. CERT-FR (updated 22 October) confirms proof-of-concept code for both flaws, with no confirmed active exploitation. The number of vulnerable sites in Africa is unknown.

À retenir : quand plusieurs autorités alertent en même temps, traitez-le comme une priorité commune.

Takeaway: when several authorities alert at once, treat it as a shared priority.

ÉLEVÉ HIGH

Menace mondiale : un accès « sauvegarde » détourné ouvre des comptes Microsoft 365

Global watch: a hijacked "backup" access opens Microsoft 365 tenants

À la mi-octobre, un attaquant a utilisé l'identité d'application de **ConnectWise Cloud Backup** (ex-SkyKick) pour entrer dans les comptes **Microsoft 365** de clients qui l'avaient autorisée : **plus de 160 organisations** selon Huntress (16 octobre), et d'autres depuis. La **MFA n'a pas été contournée** : un accès « application » n'en utilise pas. ConnectWise a arrêté le service le 17 octobre.

In mid-October an attacker used the application identity of ConnectWise Cloud Backup (ex-SkyKick) to enter the Microsoft 365 tenants of customers who had authorised it: over 160 organisations per Huntress (16 October), more since. MFA was not bypassed: an "application" access does not use it. ConnectWise stopped the service on 17 October.

À retenir : passez en revue les applications tierces autorisées dans Microsoft 365 et retirez celles que vous n'utilisez plus.

Takeaway: review the third-party apps authorised in Microsoft 365 and remove those you no longer use.

Le coin conformité — DGSSI & CNDP / Compliance corner

Les **bulletins d'alerte de la DGSSI** (cadre de la **loi 05-20** et de la **DNSSI**) sont des recommandations à suivre vite : celui de cette semaine sur PHP en est un bon exemple. Un site compromis qui héberge des formulaires ou des comptes clients peut exposer des **données personnelles** : la **loi 09-08**, sous le contrôle de la **CNDP**, impose de les protéger, d'où l'intérêt de **noter ce que vous avez corrigé et quand**. Si des données ont pu être exposées, évaluez vos obligations auprès de la CNDP.

DGSSI alert bulletins (under Law 05-20 and the DNSSI) are recommendations to act on quickly: this week's PHP bulletin is a good example. A compromised site that hosts forms or customer accounts can expose personal data: Law 09-08, overseen by the CNDP, requires protecting it, hence the value of recording what you fixed and when. If data may have been exposed, assess your duties to the CNDP.

Votre check-list en 3 minutes / Your 3-minute checklist

- [ ] **PHP** — vérifiez la version sur tous vos serveurs web et passez à 8.2.35, 8.3.36, 8.4.27 ou 8.5.12 (CVE-2026-109618/109619).
  PHP — check the version on all your web servers and move to 8.2.35, 8.3.36, 8.4.27 or 8.5.12.
- [ ] **Inventaire des sites** — recensez aussi les anciens sites oubliés ou gérés par un prestataire.
  Site inventory — include old forgotten sites or those run by a supplier.
- [ ] **Microsoft 365** — dans Entra ID, passez en revue les applications autorisées ; retirez ConnectWise/SkyKick si vous ne les utilisez pas.
  Microsoft 365 — in Entra ID, review authorised apps; remove ConnectWise/SkyKick if unused.
- [ ] **Prestataires** — demandez à votre prestataire de sauvegarde quelles applications ont accès à vos données.
  Suppliers — ask your backup provider which apps have access to your data.

Threat Pulse — Édition Maroc est fourni par DPG-Cyber à titre de sensibilisation générale et ne constitue pas un conseil de sécurité ou juridique spécifique. Informations issues de sources publiques réputées au 26 octobre 2026. · Provided for general awareness only; not specific security or legal advice.

AU-DELÀ DES GROS TITRES · BEHIND THE HEADLINES

Pourquoi une surveillance continue change tout

Why a watchful eye changes the outcome

Chaque menace de ce numéro a un point commun : les dégâts surviennent dans le **silence entre l'intrusion et le moment où quelqu'un s'en aperçoit**. Ce qui limite les dommages, c'est une surveillance continue qui corrèle les signaux, repère l'intrusion tôt et réagit avant qu'un point d'entrée ne devienne une crise.

Every threat in this issue shares one trait: the damage happens in the quiet gap between the break-in and the moment someone notices. What limits the harm is continuous monitoring that correlates the signals, spots the intrusion early, and responds before a foothold becomes a crisis.

247 jours

Temps moyen pour détecter *et* contenir une violation

Average time to identify and contain a breach

IBM COST OF A DATA BREACH 2026

$4,99M

Coût moyen mondial d'une violation de données

Global average cost of a data breach

IBM COST OF A DATA BREACH 2026

CE QUE FAIT UNE SURVEILLANCE CONTINUE / *WHAT CONTINUOUS MONITORING DOES*

Voir l'ensemble
Sees across everything

Un SIEM rassemble et corrèle l'activité de vos systèmes : les comportements anormaux ressortent au lieu de se noyer dans le bruit.

Veiller 24h/24
Watches around the clock

Les attaques n'ont pas d'horaires de bureau. Un SOC, ce sont de vraies personnes qui surveillent jour et nuit, week-ends compris.

Connaître les dernières tactiques
Knows the latest tactics

Le renseignement sur les menaces — comme les failles PHP de ce numéro — alimente la détection.

Agir, pas seulement alerter
Acts, not just alerts

Les alertes sont triées et investiguées par des analystes qui interviennent tôt, transformant un incident potentiel en non-événement.

ACTION CLIENT DE LA SEMAINE / *CLIENT ACTION OF THE WEEK*

CETTE SEMAINE · THIS WEEK

Corrigez PHP sur vos serveurs web
Patch PHP on your web servers

Faites passer PHP à **8.2.35, 8.3.36, 8.4.27 ou 8.5.12** (**CVE-2026-109618/109619**) — sur le serveur, pas seulement dans WordPress. Si c'est impossible aujourd'hui, appliquez les mesures provisoires et surveillez les journaux.

BON RÉFLEXE · GOOD HABIT

Contrôlez les accès de vos prestataires
Check your suppliers' access

Listez les prestataires (sauvegarde, infogérance, hébergement) qui ont accès à vos systèmes ou à **Microsoft 365**, retirez ceux qui ne servent plus, limitez leurs droits au minimum et revoyez la liste chaque trimestre.

C'est le travail discret, au quotidien, derrière les **services SIEM & SOC de DPG-Cyber** — la même surveillance qui transforme des gros titres comme ceux-ci en non-événements pour les entreprises que nous protégeons. Curieux de savoir ce que cela donnerait chez vous ? Écrivez-nous, sans engagement, à **hello@dpg-cyber.com**.

This is the quiet, everyday work behind DPG-Cyber's SIEM & SOC services. Curious how it would map to your environment? Drop us a line, no pressure, at hello@dpg-cyber.com.